

Veda A-91

Security Audit

July 8th, 2026

Version 1.0.0

Presented by [OxMacro](#)

Table of Contents

- [Introduction](#)
- [Overall Assessment](#)
- [Specification](#)
- [Source Code](#)
- [Issue Descriptions and Recommendations](#)
- [Security Levels Reference](#)
- [Issue Details](#)
- [Disclaimer](#)

Introduction

This document includes the results of the security audit for Veda Labs's smart contract code as found in the section titled 'Source Code'. The audit was performed by the Macro security team on July 8th, 2026.

The purpose of this audit is to review the source code of certain Veda Labs Solidity contracts, and provide feedback on the design, architecture, and quality of the source code with an emphasis on validating the correctness and security of the software in its entirety.

Disclaimer: While Macro's review is comprehensive and has surfaced some changes that should be made to the source code, this audit should not solely be relied upon for security, as no single audit is guaranteed to catch all possible bugs.

Overall Assessment

The following is an aggregation of issues found by the Macro Audit team:

Severity	Count	Acknowledged	Won't Do	Addressed
Code Quality	1	-	-	1
Informational	1	-	-	-

Veda Labs was quick to respond to these issues.

Specification

Our understanding of the specification was based on the following sources:

- Discussions with the Veda Labs team.
- Available documentation in the repository.

Source Code

The following source code was reviewed during the audit:

- **Lombard BTCoc Decoder and BTC decoder main/supplemental split (from [PR 23](#))**

Commit Hash: 9ab12106d45f6e3ed0a3924fc49694e2acfad47b

Source Code	SHA256
src/base/DecodersAndSanitizers/LombardBTCocDecoderAndSanitizer.sol	887099529c9691bcc66b086a92bda42c3abcc173d20b379c75ac68c69d74890e
src/base/DecodersAndSanitizers/LombardBtcDecoderAndSanitizer.sol	8faec49325f1e6d327ef4fea20066f53013a1fb3dcb44b6250d94b481e92b43a
src/base/DecodersAndSanitizers/LombardBtcSupplementalDecoderAndSanitizer.sol	cc042b401091f136a8d968a78449b84a4fa90926bcc238979e601f59991f478b

Note: This document contains an audit solely of the Solidity contracts listed above. Specifically, the audit pertains only to the contracts themselves, and does not pertain to any other programs or scripts, including deployment scripts.

Issue Descriptions and Recommendations

Click on an issue to jump to it, or scroll down to see them all.



Stale natspec after the main/supplemental split

I-1

`requestRedeem` settles in the base asset (BTC.b) and is fulfilled asynchronously

Security Level Reference

We quantify issues in three parts:

1. The high/medium/low/spec-breaking **impact** of the issue:
 - How bad things can get (for a vulnerability)
 - The significance of an improvement (for a code quality issue)
 - The amount of gas saved (for a gas optimization)
2. The high/medium/low **likelihood** of the issue:
 - How likely is the issue to occur (for a vulnerability)
3. The overall critical/high/medium/low **severity** of the issue.

This third part – the severity level – is a summary of how much consideration the client should give to fixing the issue. We assign severity according to the table of guidelines below:

Severity	Description
(C-x) Critical	We recommend the client must fix the issue, no matter what, because not fixing would mean significant funds/assets WILL be lost.
(H-x) High	We recommend the client must address the issue, no matter what, because not fixing would be very bad, or some funds/assets will be lost, or the code's behavior is against the provided spec.
(M-x) Medium	We recommend the client to seriously consider fixing the issue, as the implications of not fixing the issue are severe enough to impact the project significantly, albeit not in an existential manner.
(L-x) Low	The risk is small, unlikely, or may not be relevant to the project in a meaningful way. Whether or not the project wants to develop a fix is up to the goals and needs of the project.
(Q-x) Code Quality	The issue identified does not pose any obvious risk, but fixing could improve overall code quality, on-chain composability, developer ergonomics, or even certain aspects of protocol design.
(I-x) Informational	Warnings and things to keep in mind when operating the protocol. No immediate action required.
(G-x) Gas Optimizations	The presented optimization suggestion would save an amount of gas significant enough, in our opinion, to be worth the development cost of implementing it.

Issue Details



Stale natspec after the main/supplemental split

TOPIC	Stale Comments	
STATUS	Fixed ↗	
QUALITY IMPACT	Low	Documentation only; no effect on sanitization behavior.

Several protocol decoders were moved out of `LombardBtcDecoderAndSanitizer` into `LombardBtcSupplementalDecoderAndSanitizer`. However, several override `natspec` comments in the main composite were not updated to match the narrowed `override(...)` lists.

For example, the `redeem(uint256,address,address,uint256)` override is now `override(FluidFTokenDecoderAndSanitizer)` only, but is still documented as:

```
/**
 * @notice Resolve, and FluidFToken all specify a `redeem(uint256,address,a
 *         all cases are handled the same way.
 */
```

`Resolve` now lives in the supplemental, so the comment no longer reflects the inheritance. Consider updating these comments so the documentation matches the post-split composition.

requestRedeem settles in the base asset (BTC.b) and is fulfilled asynchronously

TOPIC	Expanded Behavior
IMPACT	Informational *

The `LombardBTCocDecoderAndSanitizer` sanitizes two functions of the BTCoc "Bitcoin Onchain Credit Strategy" vault: `deposit(address depositAsset, uint256 assets, address receiver)` and `requestRedeem(uint256 shares, address owner)`. Both fund-flow addresses are extracted, and the accompanying Merkle leaves pin `receiver` and `owner` to the BoringVault, so no funds can be misdirected.

Two behaviors of the underlying strategy are worth documenting for integrators and downstream accounting:

- **Deposits are multi-asset, redemptions are single-asset.** The strategy whitelists both LBTC and BTC.b as deposit assets (`getAssets()`), and leaves are generated for both. Redemptions, however, are always denominated and paid in the strategy's single base asset, BTC.b (`asset() = 0xB0F70C0bD6FD87dbEb7C10dC692a2a6106817072`), regardless of which asset was deposited. A round-trip therefore leaves the vault holding BTC.b rather than the asset it entered with.
- **Redemptions are asynchronous.** `requestRedeem` only burns the shares and records a claim; the underlying payout is pushed later by a BTCoc operator holding `PAY_REDEMPTIONS_ROLE` via `fulfillRedeemRequests`, subject to a one-block minimum delay between request and fulfillment. Until fulfillment, the vault holds a pending claim rather than the asset.

Both are the intended design of the strategy. This note is informational so that the vault's accountant is configured to price BTCoc shares and BTC.b, and so that a

BTC.b exit route remains available to the strategist after redemption.

No vulnerabilities are introduced.

Disclaimer

Macro makes no warranties, either express, implied, statutory, or otherwise, with respect to the services or deliverables provided in this report, and Macro specifically disclaims all implied warranties of merchantability, fitness for a particular purpose, noninfringement and those arising from a course of dealing, usage or trade with respect thereto, and all such warranties are hereby excluded to the fullest extent permitted by law.

Macro will not be liable for any lost profits, business, contracts, revenue, goodwill, production, anticipated savings, loss of data, or costs of procurement of substitute goods or services or for any claim or demand by any other party. In no event will Macro be liable for consequential, incidental, special, indirect, or exemplary damages arising out of this agreement or any work statement, however caused and (to the fullest extent permitted by law) under any theory of liability (including negligence), even if Macro has been advised of the possibility of such damages.

The scope of this report and review is limited to a review of only the code presented by the Veda Labs team and only the source code Macro notes as being within the scope of Macro's review within this report. This report does not include an audit of the deployment scripts used to deploy the Solidity contracts in the repository corresponding to this audit. Specifically, for the avoidance of doubt, this report does not constitute investment advice, is not intended to be relied upon as investment advice, is not an endorsement of this project or team, and it is not a guarantee as to the absolute security of the project. In this report you may through hypertext or other computer links, gain access to websites operated by persons other than Macro. Such hyperlinks are provided for your reference and convenience only, and are the exclusive responsibility of such websites' owners. You agree that Macro is not responsible for the content or operation of such websites, and that Macro shall have no liability to your or any other person or entity for the use of third party websites. Macro assumes no responsibility for the use of third party software and shall have no liability whatsoever to any person or entity for the accuracy or completeness of any outcome generated by such software.